Unit 5 Module Wiki: Security and Risk Standards in Industry and the Enterprise

Abinel Madzivire

1. Frequently Asked Questions:

FAQ 1: What is the difference between a cybersecurity standard, framework and regulation?

A cybersecurity standard establishes requirements or recommendations for managing information security. A framework provides a structured approach to identifying, assessing and managing cybersecurity risks. A regulation establishes legally enforceable obligations within a particular jurisdiction.

For example, ISO/IEC 27001 specifies requirements for an Information Security Management System (ISMS), while the NIST Cybersecurity Framework (CSF) 2.0 provides guidance for managing cybersecurity risks. The UK General Data Protection Regulation (UK GDPR) establishes legal obligations concerning the processing and protection of personal data.

Understanding these distinctions enables organisations to select appropriate security measures and identify mandatory compliance requirements.

FAQ 2: Why are industry-specific security standards important?

Different industries face distinct cybersecurity risks and operational requirements. Consequently, general cybersecurity controls may not adequately address every sector's security challenges.

For instance, financial institutions require strong safeguards for financial transactions and customer information, hospitals must protect sensitive patient data and clinical services, while manufacturing facilities must safeguard industrial control systems and production processes.

Industry-specific standards help organisations establish controls appropriate to their assets, operating environments and regulatory obligations.

FAQ 3: Which cybersecurity standards are most appropriate for international banks?

International banks should consider ISO/IEC 27001 for information security management, NIST CSF 2.0 for cybersecurity risk management and PCI DSS where payment card data is processed, stored or transmitted.

Banks operating within the European Union may also be subject to the Digital Operational Resilience Act (DORA), depending on their legal status and activities.

The appropriate combination of requirements depends on the bank's locations, services, payment systems and regulatory obligations.

FAQ 4: Which standards and regulations should a large hospital consider?

A UK hospital should consider ISO/IEC 27001, UK GDPR, the Data Protection Act 2018 and relevant NHS information governance and cybersecurity requirements.

Organisations accessing NHS patient information or systems may also need to complete the Data Security and Protection Toolkit.

Healthcare providers operating in the United States may be subject to HIPAA, depending on whether they qualify as covered entities or business associates.

Hospitals should place particular emphasis on confidentiality, clinical system availability, medical device security and patient safety.

FAQ 5: Which cybersecurity standards are relevant to a food manufacturing factory?

A food manufacturing factory should consider IEC 62443 for industrial automation and control system security, ISO/IEC 27001 for enterprise information security management and NIST SP 800-82 Revision 3 for operational technology security guidance.

ISO 22000 and Hazard Analysis and Critical Control Point (HACCP) procedures address food safety management rather than cybersecurity directly.

However, cybersecurity controls should support these food safety arrangements by protecting production data, industrial equipment and critical manufacturing parameters from unauthorised interference.

FAQ 6: How do security standards influence cybersecurity risk assessments?

Security standards provide structured requirements, controls and assessment criteria that help organisations evaluate their cybersecurity arrangements.

For example, ISO/IEC 27001 requires organisations to establish an information security risk assessment and treatment process.

Standards also support consistent documentation, accountability, control selection and the evaluation of residual risks.

However, compliance with a standard does not necessarily mean that all cybersecurity threats have been eliminated.

FAQ 7: How can security standards be integrated into threat modelling?

Security standards can inform threat modelling by identifying security requirements, control expectations and acceptable risk treatment approaches.

For example, an organisation using STRIDE could identify spoofing threats against an authentication system and then select appropriate access management controls using ISO/IEC 27001 or other relevant security guidance.

Similarly, an industrial organisation could use Attack Trees to examine potential attacks against programmable logic controllers and map recommended safeguards to IEC 62443.

Integrating standards into threat modelling helps ensure that security recommendations are consistent with organisational governance and applicable compliance obligations.

FAQ 8: Is ISO/IEC 27001 certification sufficient to demonstrate complete cybersecurity protection?

No. ISO/IEC 27001 certification demonstrates that an organisation's ISMS has been assessed against the standard within its defined certification scope.

It does not guarantee that an organisation is free from vulnerabilities, cyberattacks or security incidents.

Organisations must continue to undertake vulnerability assessments, monitoring, incident response testing, internal audits and continual improvement activities.

Certification also does not automatically establish compliance with every applicable industry regulation.

FAQ 9: How frequently should organisations assess compliance with cybersecurity standards?

Compliance should be evaluated regularly and following significant changes to systems, business operations, security threats or regulatory requirements.

Organisations should establish risk-based assessment schedules incorporating internal audits, technical security testing, management reviews and corrective action monitoring.

Some regulations and standards prescribe review or testing requirements. These must be followed in addition to the organisation's internal assessment schedule.

FAQ 10: What are the main challenges of implementing multiple cybersecurity standards?

Organisations implementing several standards may encounter overlapping requirements, increased compliance costs, limited technical expertise and difficulties coordinating evidence across departments.

For example, a multinational bank may need to address ISO/IEC 27001, PCI DSS, DORA and different national financial regulations simultaneously.

A practical solution is to establish an integrated governance, risk and compliance programme that maps common controls across applicable frameworks.

This can reduce duplication while maintaining evidence of compliance with each distinct requirement.

FAQ 11: What is the difference between security compliance and cybersecurity risk management?

Security compliance focuses on satisfying applicable laws, regulations, standards and contractual requirements.

Cybersecurity risk management focuses on identifying, assessing, treating and monitoring threats that could affect organisational objectives.

Although closely related, the two activities are not identical. An organisation may satisfy compliance requirements while remaining exposed to significant security risks.

Effective cybersecurity therefore requires a risk-based approach that goes beyond minimum compliance.

FAQ 12: How should an organisation select the most appropriate cybersecurity framework?

Framework selection should begin with identifying the organisation's industry, critical assets, risk exposure, operational requirements and applicable legal obligations.

Management should then evaluate the scope, suitability, cost and resource requirements of candidate frameworks.

For example, an international bank may prioritise ISO/IEC 27001, NIST CSF and PCI DSS, whereas an industrial manufacturer may place greater emphasis on IEC 62443.

The selected combination should provide adequate coverage without introducing unnecessary complexity or duplicating security activities.

2. Evaluating Threat Modelling Frameworks for an International Bank, Large Hospital and Food Manufacturing Factory

Introduction

Threat modelling is a proactive cybersecurity practice that enables organisations to identify, analyse and mitigate potential threats before they cause significant operational or financial harm. However, the suitability of a particular threat modelling methodology depends on organisational objectives, the complexity of information systems, the nature of protected assets and industry-specific regulatory requirements.

The Carnegie Mellon University Software Engineering Institute identifies several threat modelling approaches, including STRIDE, PASTA, OCTAVE, Attack Trees and VAST, each offering different capabilities and perspectives (Shevchenko et al., 2018).

This contribution evaluates suitable methodologies for an international bank, a large hospital and a large food manufacturing factory. It also recommends cybersecurity tests, mitigating controls and measures to support compliance with relevant industry standards.

Recommended Threat Modelling Frameworks

Organisation	Recommended frameworks	Principal justification
International bank	PASTA, STRIDE and Attack Trees	Protects financial transactions, confidential information and critical banking services
Large hospital	STRIDE, LINDDUN and PASTA	Addresses patient confidentiality, privacy, clinical safety and system availability
Food manufacturing factory	OCTAVE, STRIDE and Attack Trees	Protects operational technology, industrial control systems and production continuity

2.1 International Bank

Recommended frameworks: PASTA, STRIDE and Attack Trees

International banks process substantial volumes of financial transactions and sensitive customer information across interconnected digital platforms. These environments are vulnerable to cyber threats such as ransomware, financial fraud, credential theft, insider attacks and distributed denial-of-service attacks.

I recommend PASTA as the primary threat modelling methodology because it connects technical security threats with organisational objectives and financial risk. Its seven-stage approach helps banking institutions identify critical assets, evaluate potential attack scenarios and prioritise mitigation strategies.

STRIDE should complement PASTA by systematically identifying technical threats affecting online banking applications, payment gateways, application programming interfaces (APIs) and identity management systems.

Attack Trees could further support the analysis of sophisticated attacks involving account takeover, unauthorised fund transfers or privilege escalation.

Recommended cybersecurity tests

1. **Penetration testing:** Conduct authorised external and internal penetration tests on internet banking applications, payment systems and critical network infrastructure.
2. **Vulnerability assessments:** Perform authenticated vulnerability scans to identify outdated software, insecure configurations and exploitable weaknesses.

3. **Authentication testing:** Evaluate multi-factor authentication, privileged access management and resistance to credential-based attacks.
4. **Application security testing:** Assess APIs and web applications for injection vulnerabilities, broken access controls and weaknesses in session management.
5. **Incident response exercises:** Simulate ransomware incidents, fraudulent transactions and payment service disruptions using controlled tabletop or red-team exercises.
6. **Disaster recovery testing:** Verify backup integrity, recovery procedures and the bank's capacity to restore essential services within agreed recovery objectives.

Recommendations to bank management

I recommend implementing a comprehensive information security management system supported by ISO/IEC 27001 and the NIST Cybersecurity Framework 2.0.

The bank should also implement continuous security monitoring, encryption of sensitive data, strong identity and access management, supplier risk assessments and a formal vulnerability management programme.

Payment card environments should satisfy applicable PCI DSS requirements. Furthermore, international institutions must establish compliance procedures that reflect the legal and regulatory requirements of each jurisdiction in which they operate.

Where applicable, European Union financial entities should also consider the Digital Operational Resilience Act (DORA).

The bank should establish measurable security performance indicators and require senior management to review critical risks, remediation progress and operational resilience regularly.

Justification

PASTA offers the strongest overall fit because it integrates cybersecurity threats with their financial and operational consequences. However, its complexity means STRIDE and Attack Trees can provide more focused analysis of individual applications and potential attack pathways.

2.2 Large Hospital

Recommended frameworks: STRIDE, LINDDUN and PASTA

Hospitals process highly sensitive personal information while relying on digital infrastructure for electronic patient records, diagnostic services, medication management, medical equipment and clinical communications.

Cybersecurity failures can therefore have consequences extending beyond financial losses to include compromised patient confidentiality, delayed treatment and potential harm to patients.

I recommend STRIDE as the primary technical threat identification framework because it provides a systematic method for examining security weaknesses in interconnected hospital information systems.

LINDDUN should complement STRIDE by focusing on privacy-related threats involving patient information, data disclosure, identifiability and inadequate awareness or control over personal data processing.

PASTA would be particularly appropriate for high-risk clinical services requiring detailed consideration of patient safety, organisational risk and potential consequences of cyberattacks.

Recommended cybersecurity tests

1. **Vulnerability scanning:** Assess electronic patient record systems, servers, network infrastructure and connected medical devices using safe, manufacturer-approved methods.
2. **Access control testing:** Verify that medical professionals can only access patient records appropriate to their authorised responsibilities.
3. **Penetration testing:** Undertake carefully scoped and authorised testing of hospital applications and supporting infrastructure without disrupting clinical systems.
4. **Privacy assessments:** Conduct data protection impact assessments where processing activities are likely to create high risks to individuals' rights and freedoms.
5. **Ransomware response exercises:** Evaluate clinical continuity procedures during simulated loss of access to patient records and other essential services.
6. **Backup and recovery testing:** Demonstrate the ability to recover patient records and restore critical services safely.
7. **Medical device security reviews:** Examine device authentication, software support, patching arrangements and network connectivity in consultation with clinical engineering teams.

Recommendations to hospital management

Hospital management should establish a cybersecurity governance programme incorporating ISO/IEC 27001, appropriate NIST guidance and relevant healthcare security requirements.

For a UK hospital, the UK General Data Protection Regulation (UK GDPR), Data Protection Act 2018 and applicable NHS Data Security and Protection Toolkit requirements are particularly important.

Management should prioritise:

- Encryption and protection of patient information.
- Role-based access controls and multi-factor authentication.
- Network segmentation separating medical devices, administrative systems and public networks.
- Continuous monitoring and timely incident escalation.
- Cybersecurity awareness training for clinical and administrative personnel.
- Tested business continuity and incident response arrangements.
- Regular supplier and medical device security assessments.

Hospitals handling NHS patient information should complete the required Data Security and Protection Toolkit assessment.

Justification

STRIDE is suitable for examining technical threats across complex healthcare systems, while LINDDUN addresses risks associated with sensitive patient information. PASTA provides additional value for safety-critical services because it connects technical incidents with patient care and organisational consequences.

Combining these methodologies offers a more comprehensive approach than relying solely on technical vulnerability identification.

2.3 Large Food Manufacturing Factory

Recommended frameworks: OCTAVE, STRIDE and Attack Trees

Modern food manufacturing facilities increasingly depend on operational technology (OT), industrial control systems (ICS), supervisory control and data acquisition (SCADA) platforms and programmable logic controllers (PLCs).

Cybersecurity attacks against these systems could interrupt production, alter manufacturing parameters, compromise product quality or create food safety risks.

I recommend OCTAVE as the primary organisational risk assessment methodology because it supports the identification of critical assets, operational threats and vulnerabilities that could affect business continuity.

STRIDE should complement OCTAVE by identifying threats to manufacturing software, industrial communication networks and control systems.

Attack Trees could be used to model specific attacks involving manipulation of production parameters, interference with automated processing systems or unauthorised access to industrial equipment.

Recommended cybersecurity tests

1. **OT asset discovery:** Identify connected production equipment, controllers, supervisory systems and their communication pathways.
2. **Configuration and vulnerability assessments:** Identify insecure settings, unsupported software and exposed industrial services using methods approved for the production environment.
3. **Network segmentation testing:** Verify that corporate IT networks are appropriately separated from production control systems.
4. **Access control testing:** Review administrative permissions, remote maintenance accounts and third-party contractor access.
5. **Incident response simulation:** Conduct tabletop exercises involving ransomware, production disruption or attempted manipulation of industrial controllers.
6. **Backup and restoration testing:** Confirm the recoverability of production configurations, operational data and essential industrial systems.
7. **Change management testing:** Verify that unauthorised modifications to production software or control parameters are detectable and preventable.

Recommendations to factory management

Management should implement an industrial cybersecurity programme aligned with IEC 62443 and NIST SP 800-82 Revision 3.

ISO/IEC 27001 can support enterprise-wide information security management, while IEC 62443 provides more specialised guidance for industrial automation and control systems.

The factory should establish strong network segmentation, secure remote access, operational monitoring, asset inventories and supplier security assurance.

All intrusive security assessments should be carefully coordinated with engineering and production teams to avoid disrupting safety-critical industrial processes.

Cybersecurity risk management should also support food safety management arrangements, including applicable Hazard Analysis and Critical Control Point (HACCP) procedures and ISO 22000 where adopted.

Although HACCP primarily addresses food safety hazards rather than cybersecurity threats, cyberattacks capable of manipulating production conditions should be considered when evaluating operational controls.

Justification

OCTAVE provides an organisational perspective on threats affecting production continuity, while STRIDE supports technical threat identification. Attack Trees enable deeper investigation of potential attacks against industrial equipment and production processes.

This combined approach is particularly valuable because food manufacturing cybersecurity must protect not only information but also physical operations and product safety.

3. Comparative Evaluation

The three organisations demonstrate why threat modelling should be tailored to the assets being protected and the potential consequences of security incidents.

For international banks, the primary security considerations include financial integrity, customer confidentiality and transaction availability.

Hospitals place additional emphasis on patient safety, privacy and continuity of clinical services.

Food manufacturers must prioritise operational technology security, production integrity, physical safety and business continuity.

Although STRIDE could be applied across all three organisations, using it alone may provide an incomplete understanding of operational and business consequences.

Conversely, complex methodologies such as PASTA can offer greater contextual insight but may require more resources and specialist expertise.

A risk-based hybrid approach can therefore provide a practical balance between analytical depth, implementation costs and organisational security requirements.

4. Common Recommendations for All Three Organisations

I recommend that management teams adopt the following common security practices:

1. Establish clear cybersecurity governance and accountability at senior management level.
2. Maintain accurate inventories of critical digital and operational assets.
3. Conduct risk-based threat modelling during system design and following significant changes.
4. Implement strong authentication and least-privilege access controls.
5. Establish vulnerability management and secure configuration procedures.
6. Undertake regular, properly authorised security testing.
7. Develop and test incident response and disaster recovery plans.

8. Provide role-specific cybersecurity awareness training.
9. Review third-party and supply chain risks.
10. Document risk assessments, remedial actions and compliance evidence.

Importantly, organisations should distinguish between adopting a threat modelling methodology and achieving compliance with statutory or industry-specific requirements.

Framework adoption provides analytical structure, whereas compliance requires evidence that applicable controls have been implemented, maintained and assessed.

5. Critical Reflection

In my assessment, the most effective threat modelling strategy is not necessarily the most technically sophisticated methodology, but the one that best reflects an organisation's critical assets, operational environment and risk tolerance.

PASTA appears particularly suitable for international banks because of its integration of business objectives and cybersecurity risk.

For hospitals, combining STRIDE and LINDDUN strengthens both technical security analysis and protection of sensitive personal information.

For food manufacturing facilities, OCTAVE combined with STRIDE and Attack Trees provides a useful balance between organisational risk management and protection of industrial systems.

A particularly important consideration is the relationship between cybersecurity and physical consequences. For example, an attack against an online banking application may result in financial losses, while interference with medical equipment or food production controls could have direct implications for human health and safety.

Therefore, cybersecurity prioritisation should reflect the severity of potential consequences rather than relying exclusively on numerical vulnerability scores.

6. Conclusion

Threat modelling plays a critical role in strengthening organisational cybersecurity by identifying potential threats, evaluating vulnerabilities and informing proportionate security controls.

International banks, hospitals and food manufacturing facilities operate in different risk environments and therefore benefit from different combinations of threat modelling frameworks.

PASTA, STRIDE, LINDDUN, OCTAVE and Attack Trees provide complementary perspectives that can strengthen security assessment when applied appropriately.

Nevertheless, implementing these methodologies is insufficient without regular security testing, effective risk governance, continuous monitoring and compliance with relevant industry standards.

Ultimately, organisations should integrate threat modelling into their wider security management processes and continuously reassess their controls as threats, technologies and operational requirements evolve.

References

Food Standards Agency (FSA) (n.d.) *Hazard Analysis and Critical Control Point (HACCP)*. Available at: https://www.food.gov.uk/business-guidance/hazard-analysis-and-critical-control-point-haccp (Accessed: 8 October 2026).

Information Commissioner's Office (ICO) (n.d.) *A guide to data security*. Available at: https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/security/a-guide-to-data-security/ (Accessed: 8 October 2026).

International Organization for Standardization (ISO) (2022) *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Geneva: ISO.

National Health Service (NHS) England (n.d.) *Data Security and Protection Toolkit*. Available at: https://www.dsptoolkit.nhs.uk/ (Accessed: 8 October 2026).

National Institute of Standards and Technology (NIST) (2023) *Guide to Operational Technology (OT) Security*. NIST Special Publication 800-82 Revision 3. Gaithersburg, MD: NIST. Available at: https://doi.org/10.6028/NIST.SP.800-82r3 (Accessed: 8 October 2026).

National Institute of Standards and Technology (NIST) (2024) *The NIST Cybersecurity Framework (CSF) 2.0*. NIST Cybersecurity White Paper 29. Gaithersburg, MD: NIST. Available at: https://doi.org/10.6028/NIST.CSWP.29 (Accessed: 8 October 2026).

OWASP (n.d.) *Threat Modeling Cheat Sheet*. Available at: https://cheatsheetseries.owasp.org/cheatsheets/Threat_Modeling_Cheat_Sheet.html (Accessed: 8 October 2026).

PCI Security Standards Council (2024) *Payment Card Industry Data Security Standard (PCI DSS): Requirements and Testing Procedures, Version 4.0.1*. Available at: https://www.pcisecuritystandards.org/document_library/ (Accessed: 8 October 2026).

Shevchenko, N., Chick, T.A., O'Riordan, P., Scanlon, T.P. and Woody, C. (2018) *Threat Modeling: A Summary of Available Methods*. Pittsburgh, PA: Carnegie Mellon University Software Engineering Institute. Available at: https://www.sei.cmu.edu/blog/threat-modeling-12-available-methods/ (Accessed: 8 October 2026).